



ZAP by
Checkmarx

Reporte ZAP - SistemaEducacion

Sitio: <http://localhost:5173>

Generado a sáb, 3 oct 2026 17:14:26

ZAP Versión: 2.17.0

ZAP by [Checkmarx](#)

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	1
Medio	3
Bajo	2
Informativo	3

Insights

Level	Razón	Site	Descripción	Statistic
Medio	Exceeded Low		Percentage of memory used	91
Bajo	Advertencia		ZAP errors logged - see the zap. log file for details	4
Bajo	Advertencia		ZAP warnings logged - see the zap. log file for details	58
Información	Informativo	http://localhost:5173	Percentage of responses with status code 1xx	1 %
Información	Informativo	http://localhost:5173	Percentage of responses with status code 2xx	46 %
Información	Exceeded Low	http://localhost:5173	Percentage of responses with status code 4xx	28 %

Información	Exceeded Low	http://localhost:5173	Percentage of responses with status code 5xx	25 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type image/png	1 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type image/svg+xml	1 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type image/webp	1 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type text/html	4 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type text/javascript	90 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with method GET	100 %
Información	Informativo	http://localhost:5173	Count of total endpoints	73
Información	Exceeded Low	http://localhost:5173	Percentage of slow responses	11 %
Información	Informativo	http://localhost:8000	Percentage of responses with status code 2xx	50 %
Información	Informativo	http://localhost:8000	Percentage of responses with status code 4xx	50 %
Información	Informativo	http://localhost:8000	Percentage of endpoints with content	50 %

			type application /json	
Información	Informativo	http://localhost:8000	Percentage of endpoints with content type text /html	50 %
Información	Informativo	http://localhost:8000	Percentage of endpoints with method OPTIONS	50 %
Información	Informativo	http://localhost:8000	Percentage of endpoints with method POST	50 %
Información	Informativo	http://localhost:8000	Count of total endpoints	2
Información	Informativo	http://localhost:8000	Percentage of slow responses	100 %
Información	Informativo	https://beacons.gcp.gvt2.com	Percentage of responses with status code 2xx	100 %
Información	Informativo	https://beacons.gcp.gvt2.com	Percentage of endpoints with content type application /javascript	100 %
Información	Informativo	https://beacons.gcp.gvt2.com	Percentage of endpoints with method POST	100 %
Información	Informativo	https://beacons.gcp.gvt2.com	Count of total endpoints	2
Información	Informativo	https://beacons.gcp.gvt2.com	Percentage of slow responses	100 %
Información	Informativo	https://clientservices.googleapis.com	Percentage of responses with status code 2xx	100 %
Información	Informativo	https://clientservices.googleapis.com	Percentage of endpoints with content type text /plain	100 %
			Percentage of	

Información	Informativo	https://clientservices.googleapis.com	endpoints with method POST	100 %
Información	Informativo	https://clientservices.googleapis.com	Count of total endpoints	2
Información	Informativo	https://clientservices.googleapis.com	Percentage of slow responses	100 %
Información	Informativo	https://content-autofill.googleapis.com	Percentage of responses with status code 2xx	100 %
Información	Informativo	https://content-autofill.googleapis.com	Percentage of endpoints with content type text/plain	100 %
Información	Informativo	https://content-autofill.googleapis.com	Percentage of endpoints with method GET	100 %
Información	Informativo	https://content-autofill.googleapis.com	Count of total endpoints	1
Información	Informativo	https://content-autofill.googleapis.com	Percentage of slow responses	100 %
Información	Informativo	https://fonts.googleapis.com	Percentage of responses with status code 2xx	100 %
Información	Informativo	https://fonts.googleapis.com	Percentage of endpoints with content type text/css	100 %
Información	Informativo	https://fonts.googleapis.com	Percentage of endpoints with method GET	100 %
Información	Informativo	https://fonts.googleapis.com	Count of total endpoints	1
Información	Informativo	https://fonts.googleapis.com	Percentage of slow responses	100 %
Información	Informativo	https://fonts.gstatic.com	Percentage of responses with status code 2xx	100 %
			Percentage of endpoints	

Información	Informativo	https://fonts.gstatic.com	with content type font /woff2	100 %
Información	Informativo	https://fonts.gstatic.com	Percentage of endpoints with method GET	100 %
Información	Informativo	https://fonts.gstatic.com	Count of total endpoints	4
Información	Informativo	https://fonts.gstatic.com	Percentage of slow responses	56 %
Información	Informativo	https://update.googleapis.com	Percentage of responses with status code 2xx	100 %
Información	Informativo	https://update.googleapis.com	Percentage of endpoints with content type application /json	100 %
Información	Informativo	https://update.googleapis.com	Percentage of endpoints with method POST	100 %
Información	Informativo	https://update.googleapis.com	Count of total endpoints	5
Información	Informativo	https://update.googleapis.com	Percentage of slow responses	100 %

Alertas

Nombre	Nivel de riesgo	Número de Instancias
Ruta Transversal	Alto	2
Cabecera Content Security Policy (CSP) no configurada	Medio	3
Falta atributo de integridad de recursos secundarios	Medio	3
Falta de cabecera Anti-Clickjacking	Medio	3
Divulgación de Marcas de Tiempo - Unix	Bajo	1
Falta encabezado X-Content-Type-Options	Bajo	Systemic
Aplicación Web Moderna	Informativo	3
Divulgación de Información - Información sensible en URL	Informativo	1
Divulgación de información - Comentarios sospechosos	Informativo	16

Detalles de la Alerta

Alto	Ruta Transversal
Descripción	La técnica de ataque Path Traversal permite a un atacante acceder a los archivos, directorios y comandos que potencialmente residen fuera del directorio raíz de documentos web. Un atacante puede controlar una URL de tal forma que el sitio web ejecutará o mostrará la información de los archivos que son arbitrarios en cualquier parte del servidor web. Cualquier dispositivo que se exponga a una interfaz que se basa en HTTP es potencialmente vulnerable a un Path Traversal. La mayoría de los sitios web prohíben el acceso de los usuarios a algún sitio específico del sistema de los archivos, normalmente denominado directorio "raíz del documento web" o "raíz CGI". Estos directorios poseen los archivos que están destinados al acceso del usuario y el ejecutable que es necesario para poder controlar la funcionalidad correcta de la aplicación web. Para poder ingresar a los archivos o activar los comandos en cualquier zona del sistema de los archivos, los ataques de trayectoria de rutas van a utilizar la capacidad de las secuencias de todos los caracteres especiales. El ataque Path Traversal más elemental utiliza la secuencia de los caracteres especiales "../" para poder modificar la ubicación del recurso que es requerido en la URL. Aunque la gran mayoría de los servidores web que son populares van a evitar que esta técnica se escape de la raíz del documento web, las codificaciones que son alternativas de la secuencia "../" pueden impedir los filtros de seguridad. Estas variaciones del método incluyen la codificación Unicode válida y no válida ("%u2216" o "%c0%af") del carácter de la barra oblicua, los caracteres de la barra invertida ("..\") en los servidores basados en Windows, los caracteres codificados de la URL ("%2e%2e%2f"), y la codificación doble de la URL ("%255c") del carácter de la barra invertida. Inclusive si el servidor web impide de forma correcta los intentos de trayectoria en la ruta de la URL, una aplicación web en sí misma puede ser muy vulnerable provocado por el manejo de forma incorrecta de la entrada que fue proporcionada por el usuario. Este es un problema muy común de las aplicaciones web que utilizan los mecanismos de plantilla o cargan algún texto estático de los archivos. En las variaciones de los ataques, el valor del parámetro de la URL original se modifica por el nombre de uno de los archivos de órdenes dinámicos de la aplicación web. Provocando que, los resultados puedan mostrar el código fuente porque el archivo se interpreta como un texto en vez de como un archivo de órdenes ejecutable. Estas técnicas suelen emplear caracteres especiales adicionales, como el punto (".") para revelar el listado del directorio de trabajo actual, o los caracteres NULL "%00" para saltarse las comprobaciones rudimentarias de la extensión de los archivos.
URL	http://localhost:5173/node_modules/.vite/deps/lucide-react.js?v=%2Flucide-react.js
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/lucide-react.js (v)
Método	GET
Ataque	/lucide-react.js
Evidencia	
Otra información	
URL	http://localhost:5173/node_modules/.vite/deps/rolldown-runtime-DC62tzP2.js?v=%2Frolldown-runtime-DC62tzP2.js
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/rolldown-runtime-DC62tzP2.js (v)
Método	GET
Ataque	/rolldown-runtime-DC62tzP2.js
Evidencia	
Otra información	

Instancia	2
Solución	Asuma que toda la entrada es maliciosa. Utilizar una estrategia de validación de entradas de tipo "aceptar lo bueno conocido", es decir, utilizar una lista de entradas aceptables que se ajusten estrictamente a las especificaciones. Rechace cualquier entrada que no se adapte de forma estricta a las especificaciones, o cambíelas por algo que sí lo haga. No confíe exclusivamente en la búsqueda de entradas maliciosas o malformadas (es decir, no confíe en una lista de denegación). Sin embargo, las listas de denegación pueden ser útiles para detectar posibles ataques o para determinar qué entradas están tan malformadas que deben ser rechazadas directamente. Al realizar la validación de entrada, usted debe considerar todas las propiedades potencialmente destacadas, incluida la longitud, el tipo de entrada, el rango completo de valores aceptables, las entradas faltantes o adicionales, la sintaxis, el sentido entre los campos que se encuentran relacionados y la conformidad con todas las reglas comerciales. Como ejemplo de lógica de regla de negocio, "barco" puede ser sintácticamente válido porque sólo contiene caracteres alfanuméricos, pero no es válido si se esperan colores como "rojo" o "azul". Para los nombres de archivo, utilice listas de permisos estrictas que limiten el conjunto de caracteres a utilizar. Si es posible, solo permita un solo carácter "." en el nombre del archivo para poder prevenir las vulnerabilidades y rechazar los separadores de directorios como por ejemplo "/". Utilice una lista de extensiones de archivo permitidas. Advertencia: si usted intenta limpiar sus datos, tiene que hacerlo para que el resultado final no esté en la forma en el que estos puedan ser un peligro. Un mecanismo para desinfectar puede provocar la eliminación de caracteres como por ejemplo "." y ";" que pueden ser necesitados para varias explosiones. Un atacante puede intentar burlar al mecanismo de desinfección para que este "limpie" los datos de una forma que puede ser muy peligrosa. Supongamos que el atacante logra inyectar un "." dentro de un nombre de un archivo (por ejemplo, "archivo sensi.tive") y el mecanismo que se encarga de desinfectar elimina el carácter que da como resultado que el nombre del archivo válido sea, "archivo sensible". Si ahora suponemos que los datos de entrada son seguros, entonces el archivo tiene la posibilidad de verse comprometido. Las entradas se deben decodificar y canonicalizar a la representación que se encuentra actualmente de manera interna de la aplicación antes de validarlas. Asegúrese de que su aplicación no pueda descodificar la misma entrada dos veces. Estos errores podrían utilizarse para eludir los esquemas de listas de permitidos introduciendo entradas peligrosas después de haberlas comprobado. Utilice alguna función de canonicalización de una ruta que fue incorporada (como <code>realpath()</code> en C) la cual origina la versión canónica de la ruta de acceso, que produce la eliminación de forma efectiva de las secuencias "." y los enlaces que son simbólicos. Ejecute su código utilizando los privilegios más bajos que se necesitan para poder realizar todas las tareas que son necesarias. Si es posible, cree unas cuentas que se encuentren aisladas con privilegios limitados que solo se utilizan para una sola tarea. De esta forma, un ataque que sea exitoso no le proporcionará al atacante el acceso de forma inmediata al resto del software o su dominio. Por ejemplo, las aplicaciones de las bases de datos muy pocas veces requieren ejecutarse como el administrador de la base de datos, en especial en las operaciones que son cotidianas. Cuando el grupo de los objetos que son aceptados, como nombre de los archivos o URL, es limitado o conocido, tiene que crear una asignación de un grupo de valores de entradas que son fijos (como ID numéricos) a los nombres de los archivos o URL que son reales, y además tiene que rechazar todas las otras entradas. Ejecute su código en un dominio de "cárcel" o un dominio que sea similar el cual imponga los límites estrictos entre el proceso y el sistema operativo. Esto puede ser que restrinja de forma efectiva a qué archivos se pueden ingresar en un directorio particular o qué comandos puede utilizar su software. Los ejemplos de niveles de sistema operativo incluyen el Unix chroot jail, AppArmor, and SELinux. Normalmente, el código proporcionado puede otorgar cierta protección. Por ejemplo, <code>java.io.FilePermission</code> en Java SecurityManager le permite especificar las restricciones en las operaciones de archivos.

	Esto puede que no sea la solución viable, y solo limita el impacto al sistema operativo; el resto de tu aplicación puede estar expuesta.
Referencia	https://owasp.org/www-community/attacks/Path_Traversal https://cwe.mitre.org/data/definitions/22.html
CWE Id	22
WASC Id	33
Plugin Id	6

Medio	Cabecera Content Security Policy (CSP) no configurada
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	3
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/

	https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medio	Falta atributo de integridad de recursos secundarios
Descripción	Falta el atributo de integridad en una etiqueta de script o enlace servida por un servidor externo. La etiqueta de integridad evita que un atacante que haya obtenido acceso a este servidor inyecte un contenido malicioso.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Otra información	
Instancia	3
Solución	Proporcionar un atributo de integridad válido a la etiqueta.
Referencia	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Medio	Falta de cabecera Anti-Clickjacking

Descripción	La respuesta no protege contra ataques de "ClickJacking". Debes incluir Content-Security-Policy con la directiva "frame-ancestors" o X-Frame-Options.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	3
Solución	Los navegadores web modernos admiten las cabeceras HTTP Content-Security-Policy y X-Frame-Options. Asegúrese de que una de ellas está configurada en todas las páginas web devueltas por su sitio/aplicación. Si espera que la página esté enmarcada solo por páginas en su servidor (por ejemplo, si forma parte de un FRAMESET), utilice SAMEORIGIN; de lo contrario, si no espera que la página esté enmarcada, utilice DENY. Alternativamente, considere implementar la directiva "frame-ancestors" de la Política de Seguridad de Contenidos.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Bajo	Divulgación de Marcas de Tiempo - Unix
Descripción	Una marca de tiempo fue revelada por la aplicación/servidor web. - Unix
URL	http://localhost:5173/node_modules/.vite/deps/react-dom_client.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/react-dom_client.js (v)
Método	GET
Ataque	

Evidencia	2080374784
Otra información	2080374784, que se evalúa como: 2035-12-04 04:53:04.
Instancia	1
Solución	Confirmar que los datos encontrados de información sobre la marca de tiempo no son sensibles, ni se pueden usar en patrones explotables de divulgación.
Referencia	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Bajo	Falta encabezado X-Content-Type-Options
Descripción	La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo de la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/favicon.svg
Nombre del Nodo	http://localhost:5173/favicon.svg
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	

Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/src/main.jsx
Nombre del Nodo	http://localhost:5173/src/main.jsx
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
Instancia	Systemic
Solución	Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web. Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.
Referencia	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021
Informativo	Aplicación Web Moderna
Descripción	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/

Método	GET
Ataque	
Evidencia	<code><script type="module">import { injectIntoGlobalHook } from "@react-refresh"; injectIntoGlobalHook(window); window.\$RefreshReg\$ = () => {}; window.\$RefreshSig\$ = () => (type) => type;</script></code>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	<code><script type="module">import { injectIntoGlobalHook } from "@react-refresh"; injectIntoGlobalHook(window); window.\$RefreshReg\$ = () => {}; window.\$RefreshSig\$ = () => (type) => type;</script></code>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	<code><script type="module">import { injectIntoGlobalHook } from "@react-refresh"; injectIntoGlobalHook(window); window.\$RefreshReg\$ = () => {}; window.\$RefreshSig\$ = () => (type) => type;</script></code>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
Instancia	3
Solución	Se trata de una alerta informativa, por lo que no es necesario realizar ningún cambio.
Referencia	
CWE Id	
WASC Id	
Plugin Id	10109

Informativo	Divulgación de Información - Información sensible en URL
Descripción	La solicitud parecía contener información sensible filtrada en la URL. Esto puede violar las políticas de cumplimiento de PCI y de la mayoría de las organizaciones. Puede configurar la lista de cadenas de esta comprobación para añadir o eliminar valores específicos de su entorno.
URL	http://localhost:5173/?token=uxgO6l6THaGH
Nombre del Nodo	http://localhost:5173/ (token)
Método	GET
Ataque	
Evidencia	token
Otra información	La URL contiene información potencialmente sensible. La siguiente cadena fue encontrada a través del patrón: token token

Instancia	1
Solución	No pase información sensible en URIs.
Referencia	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informativo	Divulgación de información - Comentarios sospechosos
Descripción	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:5173/@react-refresh
Nombre del Nodo	http://localhost:5173/@react-refresh
Método	GET
Ataque	
Evidencia	// TODO: rename these field
Otra información	The following pattern was used: \bTODO\b and was detected in likely comment: "// TODO: rename these fields to something more meaningful.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/@react-refresh
Nombre del Nodo	http://localhost:5173/@react-refresh
Método	GET
Ataque	
Evidencia	ogic is copy-pasted from similar logic in th
Otra información	The following pattern was used: \bFROM\b and was detected 2 times, the first in likely comment: "// This logic is copy-pasted from similar logic in the DevTools backend.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/axios.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/axios.js (v)
Método	GET
Ataque	
Evidencia	. `Object.prototype.username = '...'`, which *
Otra información	The following pattern was used: \bUSERNAME\b and was detected in likely comment: "/* * Walk the prototype chain (excluding the shared Object.prototype) looking for * an own `prop`. This distinguishes genuine o", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/axios.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/axios.js (v)
Método	GET
Ataque	
Evidencia	in the same key the later object in * the arg
Otra	The following pattern was used: \bLATER\b and was detected 2 times, the first in likely comment: "/* * Accepts varargs expecting each argument to be an object, then

información	* immutably merges the properties of each object and returns", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/axios.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/axios.js (v)
Método	GET
Ataque	
Evidencia	nly when it is safe from Object.prototype po
Otra información	The following pattern was used: \bFROM\b and was detected 13 times, the first in likely comment: "/* * Read `obj[prop]` only when it is safe from Object.prototype pollution. Own * properties and members inherited from a non-O", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/axios.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/axios.js (v)
Método	GET
Ataque	
Evidencia	trusted input (e.g. user-supplied header sou
Otra información	The following pattern was used: \bUSER\b and was detected in likely comment: "/* * Determine if a value is iterable via an iterator that is NOT sourced solely * from a polluted Object.prototype. Use this i", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/react-router-dom.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/react-router-dom.js (v)
Método	GET
Ataque	
Evidencia	* * Access a value from the context. If no
Otra información	The following pattern was used: \bFROM\b and was detected in likely comment: "/* * Access a value from the context. If no value has been set for the context, * it will return the context's `defaultValue`", see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/node_modules/.vite/deps/react-router-dom.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/react-router-dom.js (v)
Método	GET
Ataque	
Evidencia	, will * cause the user agent to ignore the
Otra información	The following pattern was used: \bUSER\b and was detected in likely comment: "/* * RegExp to match domain-value in RFC 6265 sec 4.1.1 *

	* domain-value = <subdomain> * ; defined", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/sileo.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/sileo.js (v)
Método	GET
Ataque	
Evidencia	128, 1)' * `` * * TODO Revisit this approa
Otra información	The following pattern was used: \bTODO\b and was detected 13 times, the first in likely comment: "/* * Create a function that maps from a numerical input array to a generic output array. * * Accepts: * - Numbers * - Color", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/sileo.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/sileo.js (v)
Método	GET
Ataque	
Evidencia	* (input, textarea, select, contenteditable) w
Otra información	The following pattern was used: \bSELECT\b and was detected in likely comment: "/* * Only block drag if clicking on a text input child element * (input, textarea, select, contenteditable) where users m", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/sileo.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/sileo.js (v)
Método	GET
Ataque	
Evidencia	/* * Reset debug counts. Manually re
Otra información	The following pattern was used: \bDEBUG\b and was detected 4 times, the first in likely comment: "/* * Reset debug counts. Manually resetting rather than creating a new * object each frame. */", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/sileo.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/sileo.js (v)
Método	GET
Ataque	
Evidencia	ce to fix a pattern where * animation.stop

Otra información	The following pattern was used: \bWHERE\b and was detected 8 times, the first in likely comment: "/* * This method is bound to the instance to fix a pattern where * animation.stop is returned as a reference from a useEffe", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/sileo.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/sileo.js (v)
Método	GET
Ataque	
Evidencia	e provided callback from running on the next
Otra información	The following pattern was used: \bFROM\b and was detected 48 times, the first in likely comment: "/* * Cancel the provided callback from running on the next frame. */", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/sileo.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/sileo.js (v)
Método	GET
Ataque	
Evidencia	performance reasons later on. By using `useCo
Otra información	The following pattern was used: \bLATER\b and was detected 5 times, the first in likely comment: "/* * Creates a constant value over the lifecycle of a component. * * Even if `useMemo` is provided an empty array as its final ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/node_modules/.vite/deps/sileo.js?v=005e7cd0
Nombre del Nodo	http://localhost:5173/node_modules/.vite/deps/sileo.js (v)
Método	GET
Ataque	
Evidencia	style as set by the user, * rather than
Otra información	The following pattern was used: \bUSER\b and was detected 8 times, the first in likely comment: "/* * If we can, we want to commit the final style as set by the user, * rather than the computed keyframe value supplied", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/pages/student/StudentDashboard.jsx
Nombre del Nodo	http://localhost:5173/src/pages/student/StudentDashboard.jsx
Método	GET
Ataque	
Evidencia	ntDashboardSkeleton from "../components/s

Otra información	The following pattern was used: \bFROM\b and was detected in likely comment: "// import StudentDashboardSkeleton from "../../components/skeletons/student /StudentDashboardSkeleton";", see evidence field for the suspicious comment/snippet.
Instancia	16
Solución	Eliminar todos los comentarios que muestren información que pueda ayudar a un atacante y solucionar el problema al que se refieren.
Referencia	
CWE Id	615
WASC Id	13
Plugin Id	10027